

NoSQL Injection

I. Khái niệm

a. Định nghĩa NoSQL

- NoSQL là một thuật ngữ tổng quát được sử dụng để mô tả các hệ thống quản lý cơ sở dữ liệu (DBMS) không sử dụng mô hình quan hệ SQL (Structured Query Language) để tổ chức dữ liệu. Thay vì đó, NoSQL thường tập trung vào các mô hình lưu trữ dữ liệu linh hoạt hơn và có thể mở rộng tốt khi xử lý dữ liệu lớn và phân tán. Có nhiều loại NoSQL databases, bao gồm:
 - + Cơ sở dữ liệu Key-Value
 - + Cơ sở dữ liệu Document
 - + Cơ sở dữ liệu Wide-Column Store
 - + Cơ sở dữ liệu Graph

b. NoSQL injection

- NoSQL injection là một lỗ hổng xảy ra khi một kẻ tấn công có khả năng can thiệp vào các truy vấn mà một ứng dụng thực hiện đến cơ sở dữ liệu NoSQL. NoSQL injection có thể cho phép kẻ tấn công:
 - + Vượt qua các cơ chế xác thực hoặc bảo vệ.
 - + Trích xuất hoặc chỉnh sửa dữ liệu.
 - + Tấn công từ chối dịch vụ.
 - + Thực thi mã tùy ý trên máy chủ.

II. Cách tấn công

- Lỗi này thường xảy ra khi ứng dụng không kiểm soát tốt dữ liệu đầu vào từ người dùng, cho phép kẻ tấn công chèn các đoạn mã độc vào các truy vấn. *Một ví dụ là chèn **\$eq** vào một yêu cầu tìm kiếm của **MongoDB** để bypass xác thực*

- Có hai loại NoSQL injection khác nhau:
 - + ***Syntax Injection***: Xảy ra khi kẻ tấn công chèn mã độc làm phá vỡ cú pháp truy vấn NoSQL. Với lỗi hỏng này, hacker có thể chèn thêm payload vào các truy vấn NoSQL không được kiểm soát đúng cách, làm thay đổi logic của câu lệnh truy vấn. Kỹ thuật này tương tự như SQL Injection, nhưng mục tiêu là phá vỡ cấu trúc cú pháp của các ngôn ngữ truy vấn trong hệ thống NoSQL như MongoDB, CouchDB, ...
 - + ***Operator Injection***: Lỗi hỏng này xảy ra khi kẻ tấn công khai thác khả năng sử dụng các toán tử như **\$gt**, **\$ne**, **\$eq**, **\$regex** của NoSQL. Bằng cách thay đổi giá trị hoặc logic của các toán tử, hacker có thể thực hiện các truy vấn không được cấp phép và truy xuất dữ liệu nhạy cảm.

III. Biện pháp phòng chống

- Kiểm soát dữ liệu đầu vào: Đây là biện pháp quan trọng nhất. Cần xác thực và giới hạn dữ liệu đầu vào bằng cách sử dụng các cơ chế kiểm tra và xác minh mạnh mẽ. Không cho phép các chuỗi lệnh từ người dùng được chèn trực tiếp vào các truy vấn mà không qua xử lý.
- Sử dụng các thư viện hoặc framework an toàn: Hãy tận dụng các thư viện và framework cung cấp các tính năng bảo mật tích hợp, như mã hóa dữ liệu, kiểm soát truy cập và chuẩn hóa các truy vấn.
- Không xây dựng truy vấn động trực tiếp từ đầu vào: Tránh sử dụng các chuỗi lệnh động từ đầu vào của người dùng. Thay vào đó, sử dụng truy vấn tham số hóa hoặc các hàm được hỗ trợ để ngăn chặn việc thay đổi cú pháp truy vấn.
- Kiểm tra và vá lỗi thường xuyên: Thực hiện kiểm tra bảo mật định kỳ và vá lỗi ngay khi phát hiện lỗi hỏng để đảm bảo hệ thống luôn an toàn.

IV. So sánh với SQL injection

	NoSQL injection	SQL injection
Cú pháp và ngôn ngữ truy vấn	Nhắm vào các cơ sở dữ liệu không quan hệ, sử dụng các ngôn ngữ truy vấn riêng của NoSQL như MongoDB, Cassandra, hay Redis. Kẻ tấn công thường tận dụng cú pháp đặc thù của NoSQL, các toán tử, và cấu trúc JSON để tấn công	Nhắm vào các cơ sở dữ liệu quan hệ (RDBMS) sử dụng ngôn ngữ SQL. Các lệnh SQL như SELECT, INSERT, UPDATE, và DELETE thường bị tấn công qua việc thay đổi cấu trúc truy vấn.
Phương pháp tấn công	Dựa vào việc thay đổi cú pháp hoặc sử dụng các toán tử truy vấn đặc biệt của NoSQL như \$gt , \$eq , \$ne để làm thay đổi kết quả truy vấn	Chủ yếu khai thác bằng cách thay đổi trực tiếp các lệnh SQL, chẳng hạn như chèn câu lệnh OR 1=1 để truy xuất tất cả dữ liệu.
Cấu trúc dữ liệu	NoSQL sử dụng các mô hình dữ liệu linh hoạt như key-value , document-based , hay graph-based , tạo nên các cách tấn công và phòng chống khác biệt	SQL sử dụng các bảng có cấu trúc cố định



V. Nguồn tham khảo

- https://knowledge-base.secureflag.com/vulnerabilities/nosql_injection/nosql_injection_vulnerability.html
- <https://viblo.asia/p/nosql-injection-eq-no-sql-injection-phan-1-m2vJPD3oJeK>
- <https://portswigger.net/web-security/nosql-injection>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team